AUDIT REPORT · AUD-2026-IAM-01

# Strong authentication and privileged access — KRL-ADM

Banque Kerlann (fictive) · KRL-ADM — console d'administration IAM

Lead auditor: **A. Auditeur** Owner: **DSI — équipe IAM** Date: **2026-11-02 23:18**

Run: **01-kerlann-adm**

## 1. Executive summary

OPINION AT TESTING

**Unsatisfactory**

| | | | |
|---|---|---|---|
| **7** controls tested | **6** findings | **0** findings closed and verified | **6** open findings |
| **0** human approvals | **8** personal data items masked in evidence | **1 min 16 s** audit duration | **$0.191 *** measured AI cost |

Critical: 1 High: 2 Medium: 3 Low: 0

### Key messages

- 6 findings across 7 controls: 1 critical, 2 high, 3 medium.
- 6 findings remain open, with an action plan, an owner and a due date.

## 2. Scope and method

| | |
|---|---|
| Engagement | AUD-2026-IAM-01 |
| Entity | Banque Kerlann (fictive) |
| System | KRL-ADM — console d'administration IAM |
| System criticality | Supporte des fonctions critiques ou importantes (DORA) |
| Environment | Pré-production de démonstration |
| Owner | DSI — équipe IAM |
| Lead auditor | A. Auditeur |
| Date | 2026-11-02 23:18 |
| Framework | DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4 |
| Work programme | drafted by AI for this engagement — pending auditor review · controls/AUD-2026-IAM-01.en.json |

### In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console
- Journalisation des actions d'administration

### Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité
- Contrôles physiques

### Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

### Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

## 3. Findings overview

| REF. | RULE | TITLE | SEVERITY | TESTED | AFTER | STATUS | DUE DATE |
|---|---|---|---|---|---|---|---|
| F-01 | PSI-4.1 | Mandatory MFA for privileged accounts | Critical | Non-compliant | | Open | 2026-12-02 |
| F-02 | PSI-4.2 | Mandatory MFA for users of critical system | High | Non-compliant | | Open | 2027-01-31 |
| F-03 | PSI-4.7 | No generic or shared admin accounts | High | Non-compliant | | Open | 2027-01-31 |
| F-04 | PSI-4.3 | Strong password policy | Medium | Non-compliant | | Open | 2027-05-01 |
| F-05 | PSI-4.4 | Account lockout after failed logins | Medium | Non-compliant | | Open | 2027-05-01 |
| F-06 | PSI-4.5 | Inactive session timeout | Medium | Non-compliant | | Open | 2027-05-01 |
| — | PSI-4.6 | Logging of administration actions | High | Compliant | | | |

## 4. Detailed findings and controls

**F-01 PSI-4.1** Mandatory MFA for privileged accounts — Critical — Non-compliant — Open

### CRITERIA

MFA is enforced for all privileged admin accounts on KRL-ADM
PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

### CONDITION

Observed: `false`
Expected: `true`
GET /api/security returned mfa_admin=False.

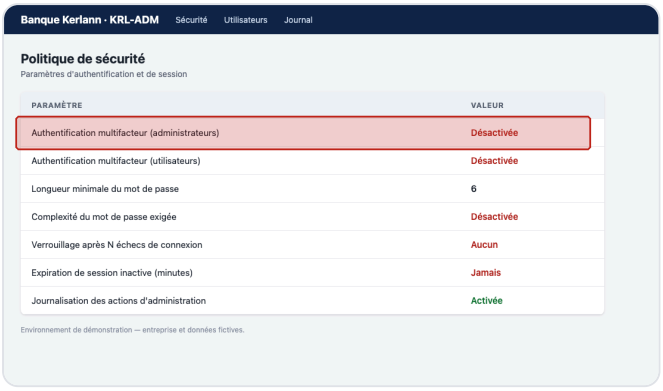
### RISK

Without MFA for admins, stolen credentials allow full takeover of critical functions with no second barrier

### RECOMMENDATION

Enable mandatory MFA for all privileged accounts by setting mfa_admin to true
Due date: 2026-12-02 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_admin is true




**At testing** — The screenshot corroborates the test. The screenshot shows admin MFA as Désactivée, matching the automated test failure.
2026-11-02 23:18:47 · SHA-256 3448a5ff18538c33…

## F-02 PSI-4.2 Mandatory MFA for users of critical system

High · Non-compliant · Open

### CRITERIA

MFA is enforced for standard users because KRL-ADM supports critical or important functions
PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

### CONDITION

Observed: `false`
Expected: `true`
mfa_users is False.

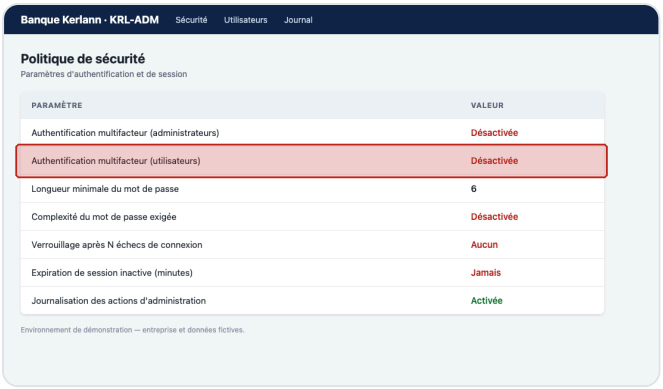
### RISK

Without MFA for all users, compromised user credentials allow unauthorized access to critical functions

### RECOMMENDATION

Enable mandatory MFA for standard users by setting mfa_users to true
Due date: 2027-01-31 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_users is true




**At testing** — The screenshot corroborates the test. The screenshot shows user MFA as Désactivée, confirming mfa_users is false.
2026-11-02 23:18:55 · SHA-256 9cdda6df7be2a389…

## F-03 PSI-4.7 No generic or shared admin accounts

High · Non-compliant · Open

### CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email
PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)

### CONDITION

Observed: `[{"login": "a.lefloch", "email": "a•••@kerlann-banque.example", "role": "admin"}, {"login": "ops", "email": "o•••@kerlann-banque.example", "role": "admin"}]`
Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`
1 of 2 admin account(s) violate nominative login or personal email requirements.

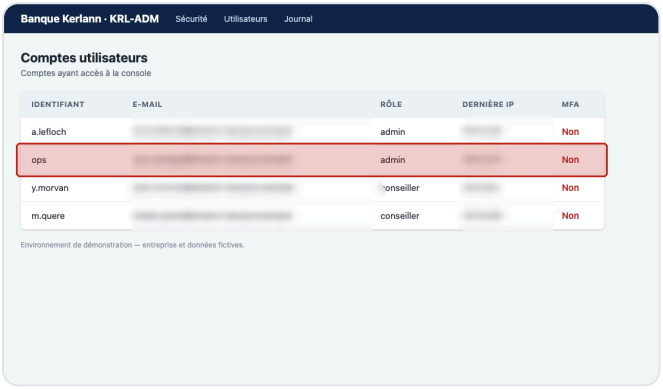
### RISK

Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

### RECOMMENDATION

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts
Due date: 2027-01-31 · Owner: DSI — équipe IAM

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox




**At testing** — The screenshot corroborates the test. The screenshot shows admin account ops with generic login and shared mailbox o•••@kerlann-banque.example, confirming the automated failure. · 8/8 personal data items masked
2026-11-02 23:19:28 · SHA-256 35fc6643d0e1d710…

## F-04 PSI-4.3 Strong password policy

Medium | Non-compliant | Open

### CRITERIA

Passwords require a minimum length of 12 characters with complexity requirements enabled
PSI-4.3 · DORA 9(4)(d)

### CONDITION

Observed: `{"password_min_length": 6, "password_require_complexity": false}`
Expected: `password_min_length >= 12 AND password_require_complexity == true`
password_min_length is 6 and password_require_complexity is False.

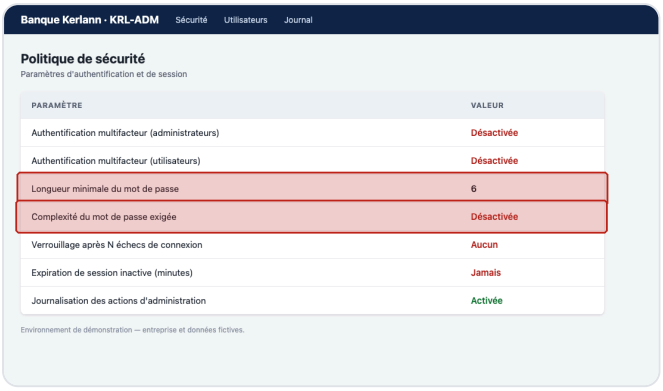
### RISK

Weak or short passwords can be guessed or brute-forced, enabling unauthorized access to the system

### RECOMMENDATION

Enforce a minimum password length of 12 characters with complexity by correcting the password settings
Due date: 2027-05-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify password_min_length and password_require_complexity




**At testing** — The screenshot corroborates the test. The screenshot shows minimum password length 6 and complexity disabled, matching the automated test failure.
`2026-11-02 23:18:50 · SHA-256 5d58be54bab35d2e…`

## F-05 PSI-4.4 Account lockout after failed logins

Medium | Non-compliant | Open

### CRITERIA

Accounts lock after at most 5 failed login attempts and lockout is never disabled
PSI-4.4 · DORA 9(4)(c)

### CONDITION

Observed: `0`
Expected: `lockout_threshold >= 1 AND lockout_threshold <= 5`
lockout_threshold is 0, which is outside the required range 1 to 5 inclusive.

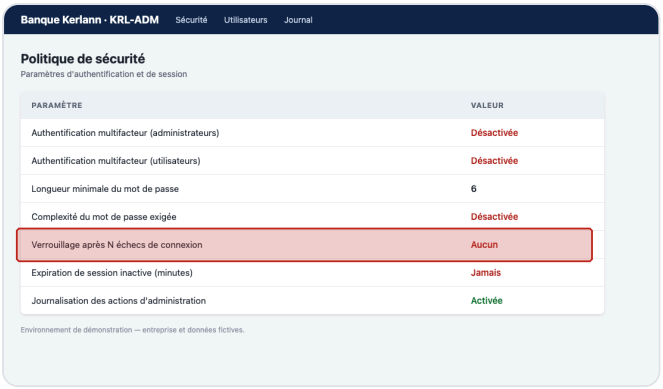
### RISK

Without lockout, attackers can perform unlimited password-guessing attacks against accounts

### RECOMMENDATION

Configure account lockout to 5 attempts at most by setting lockout_threshold between 1 and 5
Due date: 2027-05-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that lockout_threshold is between 1 and 5 inclusive




**At testing** — The screenshot corroborates the test. The screenshot shows account lockout set to Aucun, confirming the disabled lockout reported as 0.
`2026-11-02 23:18:49 · SHA-256 1e6eddba9bf76eee…`

## F-06 PSI-4.5 Inactive session timeout

Medium · Non-compliant · Open

### CRITERIA

Inactive sessions expire after at most 15 minutes and expiration is never disabled
PSI-4.5 · DORA 9(4)(c)

### CONDITION

Observed: `0`
Expected: `session_timeout_minutes >= 1 AND session_timeout_minutes <= 15`
Observed session_timeout_minutes is 0, outside the required 1 to 15 inclusive.

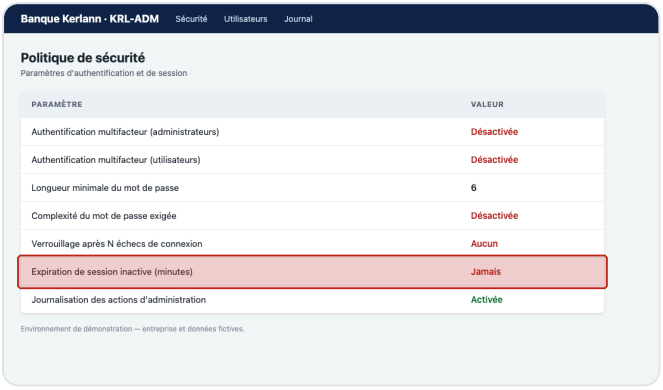
### RISK

Unlimited inactive sessions allow session hijacking and unauthorized use of unattended workstations

### RECOMMENDATION

Enforce inactive session expiration at 15 minutes at most by setting session_timeout_minutes between 1 and 15
Due date: 2027-05-01 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that session_timeout_minutes is between 1 and 15 inclusive

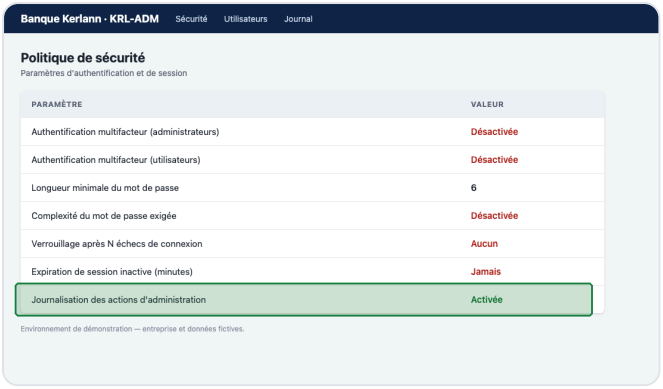



**At testing** — The screenshot corroborates the test. The security policy table shows inactive session expiration set to Never.
`2026-11-02 23:18:45 · SHA-256 ee1555412ed7d72a…`

## PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`




**At testing** — The screenshot corroborates the test. The screenshot shows Journalisation des actions d'administration as Activée, matching the automated pass result.
`2026-11-02 23:18:46 · SHA-256 c17395e7d416fb92…`

# Appendices

## A. Traceability matrix

| REQUIREMENT | RULE | CONTROL | SCRIPT (SHA-256) | RESULT |
|---|---|---|---|---|
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.1 | C1 · Mandatory MFA for privileged accounts | d82f5b5b5ad81fd1 · written by AI for this engagement | Non-compliant |
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.2 | C2 · Mandatory MFA for users of critical system | f6afe831af9933a4 · written by AI for this engagement | Non-compliant |
| DORA 9(4)(d) | PSI-4.3 | C3 · Strong password policy | 2178badc0e1bdabd · written by AI for this engagement | Non-compliant |
| DORA 9(4)(c) | PSI-4.4 | C4 · Account lockout after failed logins | d85dd8e4d3a6a030 · written by AI for this engagement | Non-compliant |
| DORA 9(4)(c) | PSI-4.5 | C5 · Inactive session timeout | 102ede4d1d4bcfda · written by AI for this engagement | Non-compliant |
| RTS 12(2)(c)(i) | PSI-4.6 | C6 · Logging of administration actions | 145e0ebb270e39fb · written by AI for this engagement | Compliant |
| DORA 9(4)(c), RTS 21(1)(c), RTS 21(3) | PSI-4.7 | C7 · No generic or shared admin accounts | 42e8a8060a7c3608 · written by AI for this engagement | Non-compliant |

## B. Evidence register

| FILE | | | SHA-256 |
|---|---|---|---|
| evidence/C1_before.png | C1 · At testing | 2026-11-02 23:18:47 | 3448a5ff18538c33f4f4140cc538a19bd4dddf24b41adaab2159557e3b071c35 |
| evidence/C2_before.png | C2 · At testing | 2026-11-02 23:18:55 | 9cdda6df7be2a389dd14eea6ff0b994f56579b246433c4971e169f0e60e0749d |
| evidence/C3_before.png | C3 · At testing | 2026-11-02 23:18:50 | 5d58be54bab35d2e46645203f0835013a191b6e52ede8ef859a5b3950dedf22e |
| evidence/C4_before.png | C4 · At testing | 2026-11-02 23:18:49 | 1e6eddba9bf76eee19e7197c0386aa1059bfaf6dbd7f9939be80b05ec6983379 |
| evidence/C5_before.png | C5 · At testing | 2026-11-02 23:18:45 | ee1555412ed7d72a5e0393b24103424a955b530dd601eed00964fff85b816b78 |
| evidence/C6_before.png | C6 · At testing | 2026-11-02 23:18:46 | c17395e7d416fb92f0f2ee68891c77544066d3c3e13d69f9cca6c2d4ac99009a |
| evidence/C7_before.png | C7 · At testing | 2026-11-02 23:19:28 | 35fc6643d0e1d710574095c54399fb48980ce5363e7a45a1c4ab99d2149e3126 |

## C. AI usage, costs and human oversight

| MODEL | CALLS | INPUT TOKENS | OUTPUT TOKENS | IMAGES | COST (USD) |
|---|---|---|---|---|---|

| | | | | | |
|---|---|---|---|---|---|
| `muse-spark-1.3` | 15 | 17,452 | 39,693 | 0 | 0.1905 |
| `sam-3.1` | 7 | 0 | 0 | 7 | price not published |
| **Total** | | | | | **0.1905** |

Personal data in evidence: 8/8 spotted by Muse Spark + SAM, 8/8 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

## Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

## D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`14b5e7c1e3ae49124f8070fc9eca972847fdf9d58e1c8fb7938a08307b2c8064`